



# Dune Discord Bot

---

## Multi-Train Release Roadmap

**Version:** v1.5.0 (main)

**Date:** 2026-07-04

**Status:** All R1.x Read-Only Complete · R2+ Planning

**No upstream PRs — local feature branches staged**

# Executive Summary

The Dune Discord Bot provides secure, read-only operational visibility for Dune Awakening dedicated servers. All commands go through a bearer-token protected adapter API. The bot never accesses the Docker socket, Postgres, game files, or shell commands directly.

## Current Metrics

| Metric           | Value                               |
|------------------|-------------------------------------|
| Tests            | 125 / 125 passing                   |
| npm audit        | 0 vulnerabilities                   |
| Semgrep SAST     | 0 findings                          |
| Gitleaks         | 0 leaks                             |
| Trivy filesystem | 0 findings                          |
| Trivy image      | 0 findings                          |
| Commands         | 19 (/dune subcommands)              |
| Source modules   | 13                                  |
| RBAC             | Restricted-by-default, fails closed |
| Addon            | Zero-permission, static HTML        |

## Release Train Overview

| Train   | Scope                   | Commands      | Status           |
|---------|-------------------------|---------------|------------------|
| R1.0.0  | Stable read-only GA     | 7 core        | MERGED           |
| R1.x    | Read-only maturity      | 12 additions  | MERGED           |
| R2.0.0  | Write-safety foundation | Framework     | FEATURE BRANCH   |
| R2.x    | Low-risk admin writes   | 6 write stubs | FEATURE BRANCHES |
| R3.0.0  | Operational writes      | 4 write stubs | FEATURE BRANCH   |
| R4.0.0+ | Highest-risk ops        | Planning      | FEATURE BRANCH   |

# R1.0.0 — Stable Read-Only GA (v1.0.0)

---

**MERGED** • Target: release/v1.0.0

## Scope

First stable release of the read-only Discord bot. Promotes the v1.0.0-rc.1 release candidate after comprehensive security gates and operator validation.

## Commands

| Command              | Mode | RBAC     | Description                 |
|----------------------|------|----------|-----------------------------|
| /dune about          | RO   | Observer | Bot and adapter metadata    |
| /dune ping           | RO   | Observer | Discord and adapter latency |
| /dune health         | RO   | Observer | Adapter health check        |
| /dune status         | RO   | Observer | High-level server status    |
| /dune status-summary | RO   | Observer | Compact aggregate status    |
| /dune readiness      | RO   | Observer | Readiness and preflight     |
| /dune services       | RO   | Observer | Service state               |

## Security Controls

- Restricted-by-default RBAC (fails closed if no principals)
- Bearer-token adapter authentication
- Secret file support (DISCORD\_BOT\_TOKEN\_FILE)
- Output redaction (credentials, PII, Steam IDs, Funcom IDs, emails, IPs)
- Zero-permission addon (addon.json permissions: [])
- Non-root Docker container (USER node), HEALTHCHECK defined
- Dependabot with 7-day cooldown
- Pinned GitHub Actions (immutable SHA)

## R1.x — Read-Only Maturity (v1.1.0-v1.5.0)

**MERGED** • Targets: release/v1.1.0 through release/v1.5.0

### Added Features

| v     | Feature                                         | Type | Source                                 |
|-------|-------------------------------------------------|------|----------------------------------------|
| 1.1.0 | Operator validation script (8 infra checks)     | RO   | scripts/validate-operator.js           |
| 1.2.0 | Population command (aggregate-only, moderator+) | RO   | src/commands.js                        |
| 1.3.0 | Notification scheduler + alert digests          | RO   | src/scheduler.js, src/notifications.js |
| 1.4.0 | Adapter compatibility drift check               | RO   | scripts/check-compatibility.js         |
| 1.5.0 | R2 readiness documentation                      | RO   | docs/releases/v1.5.0.md                |
| —     | Command cooldowns (anti-flood)                  | RO   | src/cooldown.js                        |
| —     | Backup list command                             | RO   | src/commands.js                        |
| —     | Game→Discord announcement bridge                | RO   | src/announcements.js                   |
| —     | OPS observability commands (9 domains)          | RO   | src/opsCommands.js                     |

### OPS Observability Commands

Sourced from yacketrj/dune-ops-observability-addon — all ops:read permission.

- /dune activity — Player activity (online, returning, per-guild, per-map)
- /dune combat — Combat stats (PvP/PvE, deaths by cause, K/D ratio)
- /dune resources — Resource fields (spice, water, minerals, solar, organic)
- /dune economy — Economy (currency holders, supply, orders, taxes)
- /dune inventory — Inventory and crafting statistics
- /dune location — Map markers, player density, territories
- /dune soc — OPS bridge health and request statistics
- /dune prometheus — Container metrics (CPU, memory, restarts)
- /dune dashboard — Aggregated operational dashboard summary

# Game ⇄ Discord Communication Bridge

---

MERGED

## Game → Discord (Announcements)

In-game announcements are forwarded to a configured Discord channel. The bot polls the adapter for new announcements at configurable intervals, deduplicates by ID, caps message length at 1800 characters, and redacts all output.

**Configuration:** `DUNE_ANNOUNCEMENTS_ENABLED=true`, `DUNE_ANNOUNCEMENTS_CHANNEL=channel-id`

**Implementation:** `src/announcements.js` — 7 unit tests

## Discord → Game (Broadcast)

Moderator+ roles can use `/dune broadcast <message>` to send a message to all in-game players. The command includes:

- Write-enabled gate (disabled by default)
- Moderator RBAC check
- Confirmation primitive (action, target, risk)
- Idempotency key generation
- 60-second per-user cooldown
- Tamper-evident audit event
- Message validation (1-500 printable characters)

**Configuration:** `DUNE_DISCORD_WRITES_ENABLED=true`, `DISCORD_WRITE_ADMIN_ROLE_IDS`

**Implementation:** `src/broadcast.js`, `src/writes.js` — 8 unit tests

## R2.x — Write-Capable Release Trains

**PLANNING** • Upstream write-contract required before implementation

### R2.0.0 — Write-Safety Foundation (v2.0.0)

| Component                                       | Status      | Source        |
|-------------------------------------------------|-------------|---------------|
| Write-enabled gate (disabled by default)        | IMPLEMENTED | src/writes.js |
| Write-specific RBAC (not inherited by observer) | IMPLEMENTED | src/writes.js |
| Confirmation primitives                         | IMPLEMENTED | src/writes.js |
| Idempotency key generation                      | IMPLEMENTED | src/writes.js |
| Write audit events                              | IMPLEMENTED | src/writes.js |
| Write adapter timeout and retry rules           | PENDING     | —             |
| STRIDE and abuse-case review                    | PENDING     | —             |

### R2.1-R2.4 — Low-Risk Administrative Writes

| v     | Feature                              | Branch         |
|-------|--------------------------------------|----------------|
| 2.1.0 | Maintenance note/window set commands | release/v2.1.0 |
| 2.2.0 | Notification configuration writes    | release/v2.2.0 |
| 2.3.0 | Scheduled-post configuration writes  | release/v2.3.0 |
| 2.4.0 | R3 readiness review                  | release/v2.4.0 |

### Entry Criteria (not yet met)

- Upstream publishes and approves a write-capable adapter contract
- All R1.x releases merged and stable
- Every write path defaults disabled
- No observer role can execute writes
- Confirmation cannot be bypassed

## R3.0.0 — Operational Writes (v3.0.0)

---

**PLANNING** • Branch: release/v3.0.0

### Candidate Command Families

| Command                      | Risk   | Requires Owner |
|------------------------------|--------|----------------|
| /dune create-backup          | Medium | No             |
| /dune restart-service <name> | High   | No             |
| /dune trigger-update         | High   | Yes            |
| /dune clear-cache            | Medium | No             |

### Required Controls

- Write-admin or owner role only
- Per-command allow-list support
- Maintenance-window awareness
- Cooldowns and concurrency limits
- Dry-run or impact preview
- Stronger confirmation wording
- Rollback or recovery runbook
- Audit evidence before and after side effects
- Operator smoke test before stable promotion

### Release Gates

- Release candidate required
- No stable promotion without documented operator validation
- Failure modes tested: timeout, denied auth, adapter error, duplicate retry, redaction
- Backup work includes storage, quota, and retention review
- Restart/update work includes availability impact notes

## R4.0.0+ — Highest-Risk Operations (v4.0.0+)

---

**PLANNING** • Branch: release/v4.0.0

### Candidate Areas

- Player moderation (kick, warn, ban)
- Player messaging (whisper, broadcast, admin chat)
- Gameplay-affecting configuration changes
- Restore execution
- Database-backed operations
- Two-way chat bridge (Discord ↔ game chat)

### Default Stance

- Do not implement unless upstream exposes a narrow, audited, purpose-built adapter action
- Do not expose raw database execution through Discord
- Do not start with player or restore operations
- Every action must be authorized, validated, audited, rate-limited, and reversible where practical

### Required Controls

- Owner-level authorization or equivalent
- Out-of-band approval where practical
- Enhanced privacy review
- Abuse-case review
- Audit retention expectation
- Rollback or recovery proof
- Incident response notes
- Operator training or runbook update

### Go/No-Go Gates

- Any uncertain privacy, abuse, restore, or data-integrity risk blocks merge
- Any ambiguous upstream side effect blocks merge
- Any unresolved medium, high, or critical finding blocks merge
- No stable release without at least one RC and owner approval
- R3.0.0 must be merged and operational writes proven in production



# Universal Security Gates

---

Every substantive PR, release candidate, and stable release must pass:

| Gate               | Tool                | Requirement                                                  |
|--------------------|---------------------|--------------------------------------------------------------|
| Unit tests         | node:test           | 125 passing, no failures                                     |
| Release metadata   | validate-release.js | Version alignment across package.json, addon.json, CHANGELOG |
| Addon package      | package-addon.js    | Zero-permission, checksum verified                           |
| SBOM               | generate-sbom.js    | 25 components, hash verified                                 |
| Dependency audit   | npm audit           | 0 moderate+ vulnerabilities                                  |
| Static analysis    | Semgrep             | 0 findings (auto rules)                                      |
| Secret scan        | Gitleaks            | 0 leaks (documented allowlist)                               |
| Filesystem scan    | Trivy               | 0 misconfigurations or secrets                               |
| Image scan         | Trivy               | 0 vulnerabilities in container image                         |
| Docker build       | docker              | Successful build, non-root, HEALTHCHECK                      |
| Supply chain       | Dependabot          | 7-day cooldown, major versions ignored                       |
| Workflow integrity | GitHub Actions      | Immutable SHA pins, no eval/CVE                              |

## Additional Requirements

- PR body uses transparency template (Summary, User Impact, Security Impact, Least Privilege, Tests, Known Limitations, Sources)
- Durable docs/changes/PR-#### change note
- Documentation updated with source-bound evidence
- GitHub issue created for every finding not fixed in the discovering PR
- PII and secrets redacted from PRs, issues, logs, screenshots, release notes, and artifacts

